Informe de Respuesta a Incidentes: Caso TechCo

1. Fase de Identificación El ataque comprometió activos críticos que sostienen la continuidad operativa y la confianza de los clientes de TechCo.

- **Activos Afectados:** El servidor de archivos central (datos operativos), la base de datos de clientes (información financiera y de identificación personal - PII) y los sistemas de respaldo internos.
- **Vulnerabilidades Explotadas:** Carencia de concienciación en seguridad (Security Awareness) del personal frente a tácticas de ingeniería social (Phishing). Adicionalmente, se evidenció una grave falla en la arquitectura de red al no existir segmentación, permitiendo el movimiento lateral del ransomware hacia los repositorios de backup.

2. Fase de Protección Para mitigar la superficie de ataque y prevenir futuras intrusiones, TechCo debe implementar controles preventivos robustos:

- **Arquitectura de Red Segura:** Implementar segmentación estricta (mediante VLANs y reglas de firewall como iptables) para aislar los entornos de producción de los servidores de backup. Se debe aplicar la regla 3-2-1 para los respaldos, manteniendo copias offline o inmutables.
- **Controles de Acceso y Filtros:** Desplegar soluciones de seguridad de correo (Email Security Gateways) para inspeccionar adjuntos y neutralizar dominios maliciosos.
- **Políticas Zero Trust:** Aplicar el Principio de Menor Privilegio (PoLP), asegurando que los usuarios estándar no tengan permisos de ejecución o modificación sobre directorios críticos del sistema.

3. Fase de Detección La carencia de visibilidad permitió que el ataque avanzara hasta su fase final. TechCo debe adoptar una postura de monitoreo proactivo:

- **Monitoreo Centralizado (SIEM/EDR):** Despliegue de agentes de monitoreo (como Wazuh) en los endpoints y servidores críticos para recolectar telemetría en tiempo real.
- **Reglas de Alerta Temprana:** Configurar alertas automatizadas basadas en comportamiento (Heurística), como la detección de múltiples modificaciones, lecturas o intentos de cifrado de archivos en ventanas de tiempo inusualmente cortas.

4. Fase de Respuesta Una vez detectada una anomalía, el equipo de respuesta debe ejecutar playbooks predefinidos para contener la amenaza:

- **Contención Inmediata:** Aislar lógicamente los equipos infectados desconectándolos de la red, pero *sin apagarlos*, para preservar la memoria RAM y facilitar el análisis forense posterior.
- **Roles del Equipo (CSIRT):**
    - *Incident Commander:* Coordina las acciones y toma decisiones estratégicas.
    - *Analistas SOC:* Ejecutan el aislamiento, analizan los indicadores de compromiso (IoC) e investigan el vector de entrada.
    - *Comunicaciones:* Gestiona la notificación obligatoria a los clientes afectados y autoridades reguladoras antes de 72 horas, manteniendo la transparencia.

5. Fase de Recuperación Con la amenaza erradicada de la red, se procede a la restauración de los servicios para cumplir con el Plan de Continuidad de Negocio (BCP):

- **Restauración de Sistemas:** Reimagen completa (formateo seguro) de los servidores comprometidos. Restauración de la información priorizando las bases de datos transaccionales, utilizando las copias de seguridad desconectadas y limpias.
- **Continuidad Operativa:** Habilitar infraestructuras de contingencia temporales para no interrumpir el flujo del servicio al cliente durante los trabajos de restauración.

6. Fase de Mejora Continua La gestión del incidente no termina con la recuperación. Es mandatorio documentar las debilidades del proceso:

- **Reunión Post-Mortem:** Evaluar métricas como el Tiempo Medio de Detección (MTTD) y el Tiempo Medio de Respuesta (MTTR).
- **Ejercicios de Simulación (Tabletops):** Ejecutar simulacros semestrales de incidentes de ransomware para entrenar al personal técnico y validar las actualizaciones de los planes de respuesta.